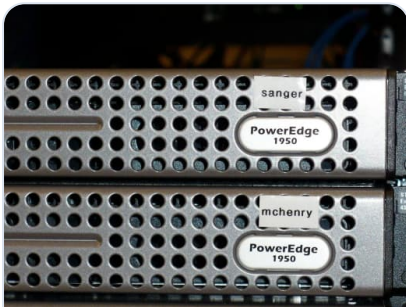


TP 2 : repérer une injection sans deviner

TP 2 · Les injections



MATÉRIEL QUE TU CROISES DANS CE LABORATOIRE



Serveur

Fournit fichiers, messagerie ou site web aux autres



Poste de travail (ordinateur fixe)

L'ordinateur de bureau utilisé chaque jour

Photos issues de Wikimedia Commons : Serveur, Florence Devouard, CC BY-SA 4.0 · Poste de travail (ordinateur fixe), Mnicolois, CC BY 4.0.

À RETENIR

- ◆ Cadre et limites : tu analyses uniquement des fichiers fournis ; ne teste jamais un système réel sans autorisation écrite.
- ◆ Les exemples ci-dessous utilisent des valeurs inventées, pas celles du labo. Ils servent à apprendre la méthode.

1 Ce qu'il faut chercher

Le labo compte une requête comme tentative si sa chaîne de requête, une fois décodée, contient l'un des motifs suivants : « ' OR '1'='1 », « UNION SELECT », « sleep(», « '-- » ou « OR 1=1 ».

Une apostrophe légitime dans un nom de ville ou de client ne suffit donc pas. Commence toujours par décoder la chaîne de requête avant de compter : « %27 » donne une apostrophe, « %20 » donne une espace, et le signe « + » vaut lui aussi une espace dans une chaîne de requête.

2 Visionneuse du site

Dans la visionneuse, cherche d'abord « %27 », puis « union », puis « sleep ». Ouvre ensuite la ligne correspondante dans le journal SQL avec l'identifiant de requête, par exemple « rid » ou « req ».

3 Exemple Bash sur des données inventées

BASH

```
cat > guide-acces-exemple.log <<'EOF'
198.51.100.30 - - [05/May/2026:08:10:00 +0000] "GET /api/recherche?ville=Dakar&rid=demo-01 HTTP/1.1" 200 812 "-"
"Mozilla/5.0"
203.0.113.200 - - [05/May/2026:08:11:00 +0000] "GET /api/recherche?ville=%27+0R+%271%27%3D%271&rid=demo-02 HTTP/1.1" 500
240 "-" "curl/8.7.1"
EOF
grep -o '"GET [^"]*"' guide-acces-exemple.log | sed 's/^"GET //; s/ HTTP\\1.1"$//' | while read -r url; do
  q="{url#*?}"
  q="{q//+ /}"
  d=$(printf '%b' "${q//%/\\x}" | tr '[:upper:]' '[:lower:]')
  case "$d" in
    '*' or '1'='1'|*"union select"*|"sleep"*|*"'"'--"*|"or 1=1"*) echo "$d" ;;
  esac
done | wc -L
```

Commande longue, coupée par la mise en page : copie-la en une seule ligne ou utilise la version texte indiquée en fin de document.

4 Exemple PowerShell 5.1 sur des données inventées

POWERSHELL

```
@(
'198.51.100.30 - - [05/May/2026:08:10:00 +0000] "GET /api/recherche?ville=Dakar&rid=demo-01 HTTP/1.1" 200 812 "-"
"Mozilla/5.0"',
'203.0.113.200 - - [05/May/2026:08:11:00 +0000] "GET /api/recherche?ville=%27+0R+%271%27%3D%271&rid=demo-02 HTTP/1.1" 500
240 "-" "curl/8.7.1"'
) | Set-Content -Encoding UTF8 guide-acces-exemple.log
$motifs = @('" or '1'='1", 'union select', 'sleep(', "'--", 'or 1=1')
$total = 0
Get-Content -Encoding UTF8 guide-acces-exemple.log | ForEach-Object {
  if ($_. -match '"GET (?<u>[^ ]+) HTTP/1.1"') {
    $decoded = [System.Uri]::UnescapeDataString($Matches.u.Replace('+', ' ')).ToLowerInvariant()
    if ($motifs | Where-Object { $decoded.Contains($_) }) { $total++ }
  }
}
$total
```

Commande longue, coupée par la mise en page : copie-la en une seule ligne ou utilise la version texte indiquée en fin de document.

5 Relier un accès et son SQL

BASH

```
cat > guide-sql-exemple.log <<'EOF'
2026-05-05T08:11:00.000Z | req=demo-02 | route=/api/recherche | db_user=demo_reader | rows=0 | duration_ms=41 |
result_user=- | sql=SELECT id FROM chambres WHERE ville = '' OR '1'='1' | params=[]
EOF
req=$(grep -o 'rid=demo-02' guide-acces-exemple.log | head -n 1 | cut -d= -f2)
grep "req=$req" guide-sql-exemple.log
```

Commande longue, coupée par la mise en page : copie-la en une seule ligne ou utilise la version texte indiquée en fin de document.

POWERSHELL

```
@('2026-05-05T08:11:00.000Z | req=demo-02 | route=/api/recherche | db_user=demo_reader | rows=0 | duration_ms=41 |  
result_user=- | sql=SELECT id FROM chambres WHERE ville = '' OR '1'='1' | params=[]) | Set-Content -Encoding UTF8  
guide-sql-exemple.log  
$req = Select-String -Path guide-acces-exemple.log -Pattern 'rid=demo-02' | Select-Object -First 1  
Get-Content -Encoding UTF8 guide-sql-exemple.log | Select-String -Pattern 'req=demo-02'
```

Commande longue, coupée par la mise en page : copie-la en une seule ligne ou utilise la version texte indiquée en fin de document.

6 Lire le code

Quand une route construit son SQL avec la donnée de l'utilisateur dans une chaîne, elle reste vulnérable même si elle retire quelques caractères. La correction correcte consiste à paramétrer la requête et à limiter les droits du compte SQL.



Pingo veille sur ta progression

Retourne au laboratoire pour valider tes réponses. Bloqué ? Ouvre d'abord l'indice de la tâche, la correction vient ensuite. Pour copier les commandes sans coupure de ligne, ouvre la [version texte](#).